SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: CRYPTOGRAPHY AND NETWORK
SECURITY COURSE CODE: CSA51

COURSE OUTCOME COVERED

CO2: Analyze Public Key crypto system strategies using RSA and key Exchange for Encryption algorithm to strengthen information security. (BL4,BL5)

Scenario-Based : 20%

QUESTIONS: Total Marks: 50 Annexure A

Code of Conduct:

I ***_P.Sunayana(192424303)_*** *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student: 

Annexure A

Scenario-based

1. Secure Data Transmission using Block Cipher

A company is transmitting repeated financial data blocks over a network. Initially, they used ECB mode and noticed patterns in ciphertext.

A. Explain why this issue occurs.

B. Suggest a more secure block cipher mode and justify your choice based on the scenario.

2. Choosing an Encryption Algorithm for Banking System

A banking application needs high security and moderate performance for encrypting customer transactions. The available options are DES, 3-DES, and Blowfish.

A. Identify the most suitable algorithm for this scenario.

B. Justify your choice based on security strength and efficiency.

3. Key Exchange in an Unsecured Network

Two users want to establish a secure communication channel over a public network using Diffie-Hellman key exchange. However, the network is vulnerable to attacks.

A. Explain how the key exchange works in this scenario.

B. Identify a possible security threat and suggest a solution to mitigate it.

4. Public Key Cryptography for Email Security

An organization plans to implement RSA for secure email communication.

A. Describe how RSA can be used for encryption and decryption in this scenario.

B. Explain how key distribution and management play a role in maintaining security.

5. Cryptography for IoT Devices

A smart home system uses low-power IoT devices that need secure communication. The designer must choose between RSA and Elliptic Curve Cryptography (ECC).

A. Analyze the constraints of IoT devices.

B. Recommend a suitable cryptographic approach and justify your answer.

RUBRICS FOR CALCULATION:

Criteria	**Weightage (%)**	**Level 4 (Exemplary)**	**Level 3 (Proficient)**	**Level 2 (Developing)**	**Level 1 (Beginning)**
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues

Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand

ANSWERS:

1. Secure Data Transmission Using Block Cipher

A. Explain why this issue occurs.

Electronic Codebook (ECB) mode encrypts each plaintext block independently using the same secret key. Therefore, identical plaintext blocks produce identical ciphertext blocks. When financial data contains repeated values or patterns, these patterns remain visible in the ciphertext, even though the actual information is encrypted. This can reveal information about the structure of the data and reduce confidentiality.

B. Suggest a more secure block cipher mode and justify your choice.

Cipher Block Chaining (CBC) mode is more secure than ECB for this scenario because each plaintext block is combined with the previous ciphertext block before encryption. The first block uses an Initialization Vector (IV). Consequently, identical plaintext blocks can produce different ciphertext blocks when encrypted with different IVs.

Justification:

- **Confidentiality:** Conceals repeated patterns in financial data.
- **Security:** Requires a fresh, unpredictable IV for each encryption under the same key.
- **Practical application:** Suitable for protecting structured financial records when implemented correctly.

Conclusion: CBC is a better choice than ECB for hiding patterns in repeated financial data. However, CBC does not provide integrity by itself; authenticated encryption, such as AES-GCM, is preferable in modern systems because it protects confidentiality and detects tampering.

---

2. Choosing an Encryption Algorithm for a Banking System

A. Identify the most suitable algorithm for this scenario.

Among the given options—DES, 3-DES, and Blowfish—**Blowfish is the most suitable choice for a legacy system that must select from these three algorithms**, provided its implementation and key management are appropriate.

B. Justify your choice based on security strength and efficiency.

Criterion	DES	3-DES	Blowfish
Key size	56 bits	Up to 168 nominal bits	32–448 bits

Security	Vulnerable to brute-force attacks	Stronger than DES, but now considered legacy	No practical general break of the full cipher is known, but it has limitations
Performance	Fast, but insecure	Slower because it performs DES operations three times	Generally efficient in software
Block size	64 bits	64 bits	64 bits
Suitability	Not recommended	Legacy compatibility only	Better among the listed options for limited legacy use

Analysis and decision:

DES has only a 56-bit key, making brute-force attacks practical. Triple DES (3-DES) improves security by applying DES three times, but it is computationally slower and has a 64-bit block size, which limits its suitability for large volumes of data.

Blowfish supports longer keys and is generally efficient in software. However, its 64-bit block size also creates limitations when encrypting large amounts of data under one key.

Conclusion: If restricted to the three options, Blowfish is a reasonable legacy choice. For a new banking application, **AES-128 or AES-256 in an authenticated mode such as AES-GCM is the recommended choice**, because these are modern standards designed for strong security and efficient operation.

---

3. Key Exchange in an Unsecured Network

A. Explain how the key exchange works in this scenario.

The Diffie–Hellman (DH) key exchange allows two users to establish a shared secret over a public network without transmitting the secret itself.

Steps involved:

1. Both users agree on public parameters: a large prime number \(p\) and a generator \(g\).
2. User A selects a private value \(a\) and calculates the public value:\[A=g^a \bmod p \]

3. User B selects a private value \(b\) and calculates:\[B=g^b \bmod p \]
4. They exchange their public values over the network.
5. User A calculates the shared secret:\[K=B^a \bmod p \]
6. User B calculates the shared secret:\[K=A^b \bmod p \]

Both obtain the same shared secret because:

\[K=g^{ab}\bmod p \]

An attacker observing the exchanged public values should not be able to feasibly calculate the shared secret when secure parameters are used.

B. Identify a possible security threat and suggest a solution.

Threat: Man-in-the-Middle (MITM) attack

An attacker can intercept the public values and establish separate DH shared secrets with both users. The attacker may then read or modify messages passing between them without either user realizing that the communication has been compromised.

Solution:

- Authenticate the exchanged public keys using digital signatures and trusted certificates.
- Verify the identity of the communicating parties.
- Use a secure, standardized protocol such as TLS with authenticated ephemeral Diffie–Hellman.
- Use approved cryptographic parameters and securely derived session keys.

Conclusion: Diffie–Hellman establishes a shared secret but does not authenticate the communicating parties by itself. Combining it with authentication prevents an attacker from successfully impersonating both users.

---

4. Public Key Cryptography for Email Security

A. Describe how RSA can be used for encryption and decryption.

RSA is an asymmetric cryptographic algorithm that uses a public key and a private key. In secure email communication, RSA can be used to protect a message's confidentiality by encrypting a randomly generated symmetric session key.

RSA process:

1. **Key generation:** The receiver generates an RSA public key and a corresponding private key.

2. **Public key distribution:** The receiver shares the public key through a trusted method, such as a digital certificate.
3. **Session key generation:** The sender generates a random symmetric key to encrypt the email content using a suitable authenticated encryption algorithm.
4. **Session key encryption:** The sender encrypts the symmetric session key using the receiver's RSA public key with a secure padding scheme such as RSA-OAEP.
5. **Transmission:** The sender sends the encrypted email content and encrypted session key to the receiver.
6. **Decryption:** The receiver uses their RSA private key to recover the session key and then decrypts the email content.

This hybrid approach is more efficient than encrypting an entire email directly with RSA.

B. Explain how key distribution and management maintain security.

Key distribution and management ensure that the correct public key belongs to the intended receiver and that private keys remain confidential.

- **Public key distribution:** Digital certificates issued by trusted Certificate Authorities help verify the ownership of public keys.
- **Private key protection:** Private keys must be securely stored and accessible only to authorized users.
- **Key rotation:** Keys should be replaced according to an established security policy.
- **Revocation:** Compromised or invalid certificates must be revoked.
- **Authentication:** The sender must verify the receiver's public key to prevent substitution attacks.
- **Digital signatures:** The sender can sign the email using their private key, allowing the receiver to verify its origin and integrity using the sender's public key.

Conclusion: RSA-based hybrid encryption provides confidentiality, while proper key distribution, certificate validation, private key protection, and digital signatures help maintain the security and authenticity of email communication.

Note that RSA encryption alone does not prove who sent an email. Digital signatures are needed for sender authentication and integrity, and modern email protocols may use other standardized hybrid encryption methods.

---

5. Cryptography for IoT Devices

A. Analyze the constraints of IoT devices.

Internet of Things (IoT) devices, such as smart locks, temperature sensors, and smart lights, have limited computing power, memory, battery capacity, and network bandwidth. They must communicate securely while consuming minimal energy and processing resources.

The main constraints are:

1. **Limited processing power:** Complex cryptographic operations can increase processing time.
2. **Low memory:** Devices may not have enough memory for resource-intensive algorithms.
3. **Battery limitations:** Excessive computation can reduce battery life.
4. **Communication overhead:** Large keys and messages consume additional bandwidth.
5. **Security requirements:** Devices must protect sensitive information against eavesdropping, impersonation, and unauthorized access.

Therefore, the cryptographic approach should provide strong security with minimal computational and communication overhead.

B. Recommend a suitable cryptographic approach and justify your answer.

Recommendation: Elliptic Curve Cryptography (ECC).

ECC is generally more suitable than RSA for resource-constrained IoT devices because it provides comparable security with significantly smaller key sizes.

Criterion	**RSA**	**ECC**
Key size	Larger keys required	Smaller keys for comparable security
Processing	Can be computationally expensive, depending on the operation	Often efficient for key establishment and digital signatures
Memory usage	Generally higher key-storage requirements	Generally lower key-storage requirements
Energy consumption	Can be higher for certain operations	Often lower overall resource requirements
Communication overhead	Larger public keys and signatures in common	Smaller public keys and signatures in common

	configurations	configurations
IoT suitability	Suitable when resources permit	Generally preferred for constrained devices

Application in a smart home system:

1. Each IoT device is provisioned with the required cryptographic credentials.
2. ECC-based key exchange establishes a shared secret between communicating devices.
3. A key derivation function generates a symmetric session key.
4. An authenticated encryption algorithm, such as AES-GCM, protects the transmitted data and detects unauthorized modifications.
5. Digital signatures or certificates can authenticate devices when required.

Justification:

ECC reduces key-storage requirements and communication overhead while providing strong security. These advantages make it suitable for battery-powered sensors and smart home devices. However, the actual performance depends on the device hardware, cryptographic implementation, and selected ECC parameters.

Conclusion: ECC is the preferred option for most resource-constrained IoT devices because it provides strong security with smaller keys and generally lower resource requirements than RSA. Combining ECC-based key establishment with authenticated symmetric encryption provides an efficient and secure communication system.